

Cloudflare Free Plan: Common Attacks against Web Applications on Cloudflare and Mitigation Recommendations

Checklist

- ☐ [Adding the site to Cloudflare](#)
 - ☐ Add the site and all DNS records from the existing provider.
 - ☐ After migrating nameservers and verifying DNS is working as anticipated, then we'd recommend proxying. This will ensure that every request going to your website goes to Cloudflare first instead of going to your origin server. **You must have your website's DNS records proxied for the security products below to be enabled.**
- ☐ [DNS records orange-clouded \(proxied\)](#)
 - ☐ Ensures that every request going to your website goes to Cloudflare first instead of going to your origin server. You must have your DNS records proxied for the security products below to be enabled.
- ☐ Leverage [Custom WAF Rules](#) and [Rate Limiting Rules](#)
 - ☐ [Challenge non-US Traffic](#)
 - ☐ Custom rules allow you to control incoming traffic by filtering requests to a zone. You can perform actions like Block or Managed Challenge on incoming requests according to rules you define.
- ☐ [Only allow Cloudflare IP addresses to access your origin server](#)
 - ☐ All traffic to [proxied DNS records](#) passes through Cloudflare before reaching your origin server. This means that your origin server will stop receiving traffic from individual visitor IP addresses and instead receive traffic from [Cloudflare IP addresses](#).
- ☐ [Enable Bot Fight Mode](#)
 - ☐ Identify traffic matching patterns of known bots, challenge or block bots, and protect static resources on your website.
- ☐ [If under attack, enable "Under Attack Mode"](#)
 - ☐ If the site is still experiencing impact and degradation after all prior steps, you can enable "Under Attack Mode" to force a challenge for all incoming requests / clients.

☐ Cache as much as you can with Cloudflare Cache Rules

- ☐ Use Cache Rules to customize cache settings on Cloudflare. Cache Rules allows you to make adjustments to what is eligible to cache, how long it should be cached and where, as well as trigger specific interactions with Cloudflare's cache and other Rules products for matching requests.

Cloudflare Fundamentals

Cloudflare's global anycast network helps mitigate DDoS attacks and boosts website performance via our reverse proxy and content delivery network (CDN) respectively. Additionally, it provides visibility into traffic volume, uptime, and performance that you can use to further secure or improve the site as well.

The intent of this document is to help sites already on Cloudflare enhance their security posture and mitigate ongoing disruption.

Features & Capabilities

- Analytics and Visibility
 - Traffic proxied can be reviewed in detail in our `Security Analytics`, which allows insights into cache performance and more.
 - [Web Analytics](#), [Health Checks](#)
- DNS & SSL/TLS Management
 - One of the fastest DNS authoritative DNS providers in the world (<https://dnsperf.com/>)
 - DNS record comments and tagging for ease of use.
- Web Traffic Filtering and Security
 - Inspect, identify, and block malicious traffic (bot traffic, exploits, vulnerabilities).
- Reverse Proxy
 - Allows for modifying web traffic and can cache content, to reduce requests and resource strain for an origin server.

Common Attack Surface Area

Websites / Web Traffic (HTTP/HTTPS)

Websites, being the front-door of most organizations, are often a common target as their outage/defacement is very public and disruptive. Below are some characteristics and recommendations for mitigating these attacks with Cloudflare.

Characteristics

- Types of Attacks
 - Usually a type of Layer 7 attack.
 - [Cloudflare DDoS Protection Coverage - Developer Docs](#)
- Often High Volume
 - Volume often measured in requests per second (rps).
 - Origin Unavailability / High Origin Response Times (likely due to the origin being saturated on CPU, Network, etc)
- Increase in Origin Errors (500s, 502s)
- [Web DDoS Attack](#)
 - Origin unavailability: User access issues and inaccessible web services.
- [Web Fuzzing Attack](#)
- Exploits: [Cross-Site Scripting \(XSS\)](#), [Remote Code Execution \(RCE\)](#), [SQL Injection \(SQLi\)](#)

Recommendations

- [Cloudflare's free WAF Managed Rules](#)
- WAF Rules:
 - [Challenge non-US Traffic](#)
 - [Generic Rate Limiting Rules](#)
 - [Anti-Fuzzing Rate-Limiting Rules](#)

Internet Infrastructure (IP Addresses, Domains)

In addition to websites that are often intentionally made public, attackers will scan for common DNS records such as [vpn.mysite.com](#) or [remote.mysite.com](#) to uncover critical infrastructure that's unproxied or exposing important IPs. Exposing these IPs may allow them to attack around Cloudflare.

Characteristics

- Types of Attacks
 - Usually a type of Layer 3 / Layer 4 attack.
 - [Cloudflare DDoS Protection Coverage - Developer Docs](#)
 - DNS-specific attacks are considered L7.
 - Random hostnames, query floods, etc
 - [Cloudflare DDoS Protection Coverage - Developer Docs](#)
- Often High Bandwidth and/or High Packet Rate
 - Bandwidth is often measured in bits per second (bps).
 - Packet rate is often measured in packets per second (pps).
- Internet/Network Unavailability / High Internet/Network Response Times (likely due to the internet or appliances being saturated on network or CPU)
- Cascading Infrastructure Failures (Web, VPN, Firewall, ISP Saturation)

Recommendations

- Proxying with Cloudflare
 - When proxying traffic with Cloudflare, we are able to return Cloudflare IPs as the entry point for the traffic which obscures your real infrastructure. Cloudflare has means for proxying L4, and L7. We can also onboard ASNs, or Public IP spaces
- DNS Obscurity
 - Instead of `vpn.` or `remote.` you could migrate DNS names to a random string or something unique to your organization to hide your Firewall's VPN.
 - This could mitigate attackers efforts or increase the difficulty for them to uncover real IP addresses.

Application Attack Surface Area

WordPress

Characteristics

- Brute-forcing administrator paths such as `/wp-admin/*`.
 - Account Compromise
 - Vulnerable Admin Plugins
- Often High Volume

- Origin Unavailability / High Origin Response Times (likely due to the origin being saturated on CPU, Network, etc)
- Increase in Origin Errors (500s, 502s)

Recommendations

- [Cloudflare's free WAF Managed Rules](#). All customers have access to the Cloudflare Free Managed Ruleset, which provides mitigations against high and wide-impacting vulnerabilities. This is automatically enabled on all free plans.
- WAF Rules:
 - [Challenge non-US Traffic](#)
 - [Generic Rate Limiting Rules](#)
 - [Anti-Fuzzing Rate-Limiting Rules](#)
- Cloudflare Access SSO
 - With Cloudflare Access, you can apply a policy requiring an Email PIN or Identity Provider (Azure Entra, Google Workspace) authentication before traffic can be forwarded to the origin. This is very effective at mitigating login spam to WordPress sites. Under the Cloudflare free plan, you have access to 50 free seats.

Configuration Appendix

Best Practices

The following are “Phases” or things to try to address/deploy after first onboarding DNS and proxying with Cloudflare. Before diving into these phases, there are these sections below around investigating traffic and considerations. Not all configurations are applicable to all customers.

Phase	Relevant Configurations	Configuration Work	Recommended for
Phase 1	Managed Rules Bot Fight Mode Challenge non-US Traffic	Low	All Sites
Phase 2	Generic Rate-Limiting Rules	Medium	Prominent Sites

1. Traffic Pattern Considerations

When configuring rules in Cloudflare be sure to also consider the traffic patterns you normally see and the amount of requests users make when visiting the site. You can gain insights into this in “Security > Analytics” and look for traffic from the origin for a given IP.

2. Rule Creation Considerations

Following reviewing Traffic Pattern Considerations above, and keeping the following in mind as well:

- All the rules and thresholds in screenshots in this document are examples and should not be directly copied.
- Only use the challenge actions with browser facing pages / traffic. Otherwise, automated systems interacting with APIs on your site may be disrupted.
- When first testing a rule, we would recommend using the challenge action at first so that legitimate users are still able to connect after completing the check. Then after verifying a low challenge solve rate (CSR) in the analytics view, you could more confidently move it to a blocking action.

Prevent non-Cloudflare IPs to Origin

Phase 1 Change - ([Cloudflare Developer Docs](#))

Another important step to ensuring your Cloudflare environment remains the front door for all web traffic and potential attacks after onboarding to the proxy, is to configure your firewall to limit access to the website unless the traffic is originating from Cloudflare IPs. Without this, crawlers scanning the internet may discover your server's, the origin server's, IP address and be able to bypass Cloudflare.

Free WAF Managed Rules

Phase 1 Change - ([Cloudflare Developer Docs](#))

This ruleset is automatically deployed on any new Cloudflare zone and is specially designed to reduce false positives to a minimum across a very broad range of traffic types. Customers will be able to disable the ruleset, if necessary, or configure the traffic filter or individual rules. As of today, the ruleset contains the following rules:

- Log4J rules matching payloads in the URI and HTTP headers;
- Shellshock rules;
- Rules matching very common WordPress exploits;

Security

WAF

Zone-level Web Application Firewall (WAF) detects and mitigates malicious requests across all traffic under this zone.

[WAF documentation](#)

Custom rules

Rate limiting rules

Managed rules

Tools

Managed rules

Free customers are receiving protection from the Cloudflare Free Managed Ruleset [today](#). Upgrade to receive more comprehensive protection, the full set of Cloudflare managed rules and firewall analytics.

•

Bot Fight Mode

Phase 1 Change - ([Cloudflare Developer Docs](#))

Cloudflare's Bot Fight Mode is a security feature built on the WAF that is designed to detect, manage, and mitigate bot traffic on websites and applications. Using similar threat intelligence to distinguish between good and bad bots. This protects the website from abuse, scraping, credential stuffing, DDoS attacks, and more.

1. Go to the "Security > Bots" section, and click "Configure Bot Fight Mode".

Security

Bots

Identify and mitigate automated traffic to protect your domain from bad bots.

[Bots documentation](#) 

Bot Fight Mode

Challenge requests that match patterns of known bots, before they access your site. This feature includes [JavaScript Detections](#).

Note: Other security products cannot be used to skip Bot Fight Mode. [Learn more](#)



Block AI Bots New

Block bots from scraping your content for AI applications like model training. [Learn more](#)

Note: Blocking AI Bots will also block verified AI bots.



Challenge non-US Traffic

Phase 1 Rule - ([Cloudflare Developer Docs](#))

- It is also very easy to quickly set up a challenge for all non-US traffic. This allows us to slow incoming attacks and validate the browsers before letting the users through. Under the free plan, you have access to 5 custom firewall rules.

Security

WAF

Zone-level Web Application Firewall (WAF) detects and mitigates malicious requests across all traffic under this zone.

[WAF documentation](#)[Custom rules](#) [Rate limiting rules](#) [Managed rules](#) [Tools](#)[← Back](#)**Create rule** [Custom rules](#)

Rule name (required)

Give your rule a descriptive name.

[Create rule with AI Assistant](#) Beta

Field	Operator	Value	
Country	does not equal	United States	And X
e.g. GB			
And			
Hostname	equals	cloudflarepets.com	And X
e.g. example.com			
And			
Known Bots	equals	☐	And Or X

Expression Preview

[Edit expression](#)

```
(ip.geoip.country ne "US" and http.host eq "cloudflarepets.com" and not cf.client.bot)
```

Then take action...

Choose action

Presents an interactive or non-interactive challenge to the client

Generic Rate-Limiting Rules

Phase 1 Rule - ([Cloudflare Developer Docs](#))

Cloudflare's Automatic DDoS Mitigation reduces very large volume attacks, but using rate-limiting you can control at a more granular level, the number of requests that an IP can make over a defined period. This can include a variety of attempts that contain brute force logins, smaller scale volume attacks, and scraping. Actions used to thwart these actors' efforts are blocking or issuing challenges. Under the free plan, you have access to 1 rate limiting rule.

Example 2

The following rule performs rate limiting on incoming requests with a given base URI path, incrementing on the IP address and the provided API key.

Expression:

```
(http.request.uri.path contains "/product" and http.request.method eq "POST")
```

Rule characteristics:

- *Data center ID* (included by default when creating the rule in the dashboard)
- *IP Address*
- *HTTP Header* > `x-api-key`

Example 1

The following rule performs rate limiting on incoming requests from the US addressed at the login page, except for one allowed IP address.

Expression:

```
(http.request.uri.path eq "/login" and ip.geoip.country eq "US" and ip.src ne 192.0.0.1)
```

Rule characteristics:

- *Data center ID* (included by default when creating the rule in the dashboard)
- *IP Address*

Example 3

The following rule performs rate limiting on requests targeting multiple URI paths in two hosts, excluding known bots. The request rate is based on IP address and `User-Agent` values.

Expression:

```
(http.request.uri.path eq "/store" or http.request.uri.path eq "/prices") and  
(http.host eq "mystore1.com" or http.host eq "mystore2.com") and not  
cf.client.bot
```

Rule characteristics:

- *Data center ID* (included by default when creating the rule in the dashboard)
- *IP Address*
- *HTTP Header* > `user-agent`